

Modelo de Encuesta Integral PASTA+STRIDE

Evaluación de Madurez en Modelado de Amenazas y Gestión de Riesgo Cibernético

Versión: 1.0

Alcance: Organizaciones públicas y privadas con operaciones en España

Confidencialidad: Uso interno y analítico. No se compartirán resultados individuales sin consentimiento expreso.

0. Instrucciones generales

Esta encuesta está dirigida a responsables de seguridad (CISO, responsables de riesgos, CTO, CIO, responsables de continuidad de negocio, etc.).

No es un test de penitencia: es un espejo. Puede devolver una imagen incómoda, pero nunca injusta.

Por favor:

- Responda según la práctica real de su organización en los últimos 12 meses, no según lo que diga el procedimiento ideal.
- Si una pregunta no aplica, señálelo expresamente.
- En preguntas tipo escala, utilice el rango 1 (nulo) a 5 (excelente), salvo que se indique otra cosa.

1. Perfil de la organización

1.1. Sector principal de actividad

Seleccione el sector que mejor represente el núcleo de su negocio.

- Administración pública
- Finanzas / Seguros
- Energía / Utilities
- Salud / Farmacéutico
- Industria / Manufactura
- Transporte / Logística
- Telecomunicaciones / Tecnología
- Retail / Comercio / Servicios
- Educación / Investigación
- Otro (especificar): _____

1.2. Tamaño de la organización (empleados)

- Menos de 50
- 50–249
- 250–999
- 1.000–4.999
- 5.000 o más

1.3. Alcance geográfico

- Operación local (una comunidad autónoma)
- Operación nacional
- Operación UE
- Operación internacional (UE y fuera de la UE)

1.4. ¿Está su organización sujeta a NIS2, DORA u otra regulación sectorial de ciberseguridad?

- Sí, NIS2
- Sí, DORA
- Sí, otra(s) (especificar): _____
- No / No lo sé

2. Gobernanza, estrategia y encaje del modelado de amenazas

2.1. Estrategia y liderazgo

2.1.1. ¿Existe una estrategia de ciberseguridad formalmente aprobada por la Alta Dirección o el órgano de gobierno?

- Sí, aprobada y revisada en los últimos 2 años
- Sí, pero no se revisa desde hace más de 2 años
- En elaboración
- No, se gestiona de forma táctica y dispersa
- No lo sé

2.1.2. ¿En qué medida la Alta Dirección recibe información periódica sobre amenazas y riesgos cibernéticos?

Escala 1–5 (1 = nunca, 5 = al menos trimestral, con análisis y decisión).

- 1
- 2
- 3
- 4
- 5

2.1.3. ¿Existen comités o foros formales donde se alineen negocio, riesgos y ciberseguridad?

- Sí, comité formal con participación de negocio, riesgos, TI y ciberseguridad
- Sí, pero limitado a TI y ciberseguridad
- Reuniones ad hoc sin estructura formal
- No existen tales foros
- No lo sé

2.2. Presencia del modelado de amenazas en la gobernanza

2.2.1. ¿Se menciona explícitamente el modelado de amenazas (PASTA, STRIDE u otros) en políticas, normas internas o metodologías de gestión de riesgos?

- Sí, con referencia explícita a metodologías concretas
- Sí, de forma genérica (sin citar marcos)
- No, pero se realizan prácticas similares sin nombrarlas
- No se realiza modelado de amenazas
- No lo sé

2.2.2. ¿Con qué frecuencia se revisan y actualizan los modelos de amenazas de sistemas críticos?

- Mensual
- Trimestral
- Anual
- Solo tras incidentes o grandes cambios
- No se revisan
- No aplica (no se hace modelado de amenazas)

3. Fase 1 PASTA: Objetivos de negocio y requisitos

3.1.1. Para los sistemas o servicios críticos, ¿se han definido objetivos de negocio y de misión claramente vinculados a ciberseguridad (disponibilidad, confidencialidad, integridad, trazabilidad, etc.)?

- Sí, para todos los sistemas críticos
- Sí, para algunos sistemas críticos
- Solo de forma informal o implícita
- No se han definido
- No lo sé

3.1.2. ¿En qué grado se mapean amenazas y riesgos cibernéticos a impactos de negocio cuantificables (pérdidas económicas, interrupciones de servicio, impacto reputacional, impacto regulatorio)?

Escala 1–5 (1 = no se vinculan, 5 = se cuantifican y reportan regularmente).

- 1
- 2
- 3
- 4
- 5

3.1.3. Para los sistemas bajo regulación específica (p. ej. NIS2, ENS, RGPD, DORA), ¿se han definido requisitos de seguridad derivados de dichas normas y se han integrado en los modelos de amenazas?

- Sí, plenamente
- Parcialmente
- En fase de implementación
- No
- No aplica / No lo sé

4. Fase 2 PASTA: Alcance técnico y arquitectura

4.1.1. ¿Dispone su organización de un inventario actualizado de activos y sistemas críticos (aplicaciones, servicios, infraestructuras, datos)?

- Sí, inventario centralizado y actualizado (menos de 6 meses)
- Sí, pero con actualizaciones ocasionales (más de 6 meses)
- Parcial, limitado a ciertos ámbitos (TI, OT, nube, etc.)
- No existe inventario fiable
- No lo sé

4.1.2. En relación con los sistemas críticos, ¿qué cobertura estima que tienen los modelos de amenazas frente al total de activos críticos?

- Más del 75 % de los sistemas críticos
- Entre el 50 % y el 75 %
- Entre el 25 % y el 49 %
- Menos del 25 %
- No lo sabe / No se mide

4.1.3. ¿Se documentan formalmente arquitecturas y flujos de datos (diagramas, modelos, etc.) como base para el modelado de amenazas?

- Sí, diagramas actualizados y versionados
- Sí, pero desactualizados o incompletos
- Solo para algunos proyectos específicos
- No se documentan de forma sistemática
- No lo sé

5. Fase 3 PASTA: Descomposición de aplicaciones y flujos de datos

5.1.1. Para los sistemas críticos, ¿se elaboran diagramas de flujo de datos (DFD) o modelos equivalentes para identificar flujos, almacenes de datos y límites de confianza?

- Sí, para todos los sistemas críticos
- Sí, para algunos sistemas críticos
- Solo en proyectos de alto riesgo o altamente regulados
- No se elaboran
- No lo sé

5.1.2. ¿Se identifican y documentan explícitamente los límites de confianza (trust boundaries) entre componentes, redes y organizaciones?

- Sí, de forma clara y reutilizable
- Parcialmente, de forma heterogénea
- Implícito, pero no documentado
- No se tienen en cuenta
- No lo sé

5.1.3. En una escala de 1 a 5, ¿cómo valoraría la calidad y completitud de la descomposición técnica (componentes, flujos, dependencias) en sus proyectos críticos?

- 1 (muy pobre)
- 2
- 3
- 4
- 5 (excelente)

6. Fase 4 PASTA: Análisis de amenazas (incluyendo STRIDE)

6.1. Práctica de modelado de amenazas

6.1.1. ¿Qué metodologías de modelado de amenazas se utilizan regularmente en su organización? (Puede seleccionar varias)

- PASTA
- STRIDE
- DREAD
- LINDDUN
- OWASP SAMM / OWASP Threat Modeling
- Metodología propia
- Ninguna metodología formal
- No lo sé

6.1.2. ¿En qué etapas del ciclo de vida de desarrollo o del ciclo de vida del servicio se realiza el modelado de amenazas?

- Diseño / Arquitectura
- Desarrollo
- Pruebas / Preproducción
- Producción (revisión periódica)
- Sólo tras incidentes
- No se realiza

6.1.3. Frecuencia del modelado de amenazas sobre sistemas críticos

- En cada gran cambio de arquitectura
- De forma periódica (al menos anual)
- Solo en el momento del diseño inicial
- Solo tras incidentes significativos
- No se realiza

6.2. Indicadores STRIDE

Para las siguientes preguntas, si no realiza modelado de amenazas con STRIDE u otra taxonomía, señale “No aplica”.

6.2.1. Spoofing (suplantación de identidad)

En los últimos 12 meses, ¿ha identificado amenazas o escenarios de suplantación de identidades (usuarios, servicios, APIs, dispositivos) en sus modelos de amenazas?

- Sí, de forma sistemática
- Sí, de forma parcial o reactiva
- No, pero se sospecha que existen riesgos relevantes
- No, no se han considerado
- No aplica / No lo sé

6.2.2. Controles frente a Spoofing

¿Qué nivel de adopción tienen controles como MFA, autenticación fuerte y gestión robusta de identidades en sistemas críticos?

- Muy alto (más del 80 % de los casos)
- Alto (entre 60 % y 80 %)
- Moderado (entre 40 % y 59 %)
- Bajo (menos del 40 %)
- No lo sé

6.2.3. Tampering (manipulación de datos)

En sus modelos de amenazas, ¿se analizan de forma específica escenarios de manipulación de datos, mensajes o configuraciones críticas?

- Sí, para la mayoría de sistemas críticos
- Sí, pero sólo en algunos casos específicos
- Raramente
- No se analizan
- No aplica / No lo sé

6.2.4. Repudiation (repudio, falta de trazabilidad)

¿Cómo describiría el nivel de trazabilidad y registro de eventos en sistemas críticos, desde la perspectiva de repudio?

- Alto: existe registro suficiente para reconstruir acciones y atribuir responsabilidades
- Medio: se registran eventos clave, pero con lagunas importantes
- Bajo: logs parciales, sin capacidad real de trazabilidad
- Muy bajo: logging casi inexistente
- No lo sé

6.2.5. Information Disclosure (divulgación de información)

En sus análisis, ¿se evalúa el volumen de datos sensibles y las posibles vías de fuga (APIs, terceros, nube, dispositivos, etc.)?

- Sí, con métricas y clasificación de datos
- Sí, pero sin métricas consistentes
- De forma ad hoc, sin sistemática
- No se evalúa
- No lo sé

6.2.6. Denial of Service (denegación de servicio)

¿Integra su modelado de amenazas pruebas o simulaciones relativas a degradación de servicio, disponibilidad y resiliencia?

- Sí, con pruebas y escenarios periódicos
- Sí, pero sólo en fases de diseño
- Sólo se testea capacidad técnica (p. ej. estrés) sin enlazarlo al modelo de amenazas
- No se considera
- No lo sé

6.2.7. Elevation of Privilege (elevación de privilegios)

¿Se analizan sistemáticamente rutas potenciales de escalado de privilegios en sus modelos de amenazas?

- Sí, con revisión de roles, permisos y caminos de escalado
- Sí, parcialmente
- Rara vez
- No se analizan
- No lo sé

7. Fase 5 PASTA: Vulnerabilidades y debilidades

7.1.1. ¿Existe un proceso formal para vincular amenazas identificadas en el modelado (STRIDE/PASTA) con vulnerabilidades concretas (p. ej. CVEs, findings de pentest, resultados de escáneres)?

- Sí, con trazabilidad bidireccional
- Sí, pero de forma parcial
- Sólo para algunos proyectos críticos
- No
- No lo sé

7.1.2. Tiempo medio de cierre de vulnerabilidades asociadas a escenarios de alto riesgo del modelo de amenazas

- Menos de 30 días
- 30–60 días
- 61–90 días
- Más de 90 días
- No se mide / No lo sé

7.1.3. ¿Se emplean métricas como CVSS u otras para priorizar vulnerabilidades conforme a su impacto en los escenarios de amenaza?

- Sí, CVSS adaptado al contexto de negocio
- Sí, CVSS estándar
- Se usan criterios propios
- No se emplean métricas cuantitativas
- No lo sé

8. Fase 6 PASTA: Modelado y simulación de ataques

8.1.1. ¿Se diseñan y ejecutan escenarios de ataque basados en los modelos de amenazas (p. ej. red teaming, simulaciones de ransomware, ejercicios de ataque a APIs, a cadena de suministro, etc.)?

- Sí, de forma periódica y planificada
- Sí, pero de manera ocasional y ad hoc
- Sólo ejercicios de cumplimiento (p. ej. pruebas requeridas por auditorías)
- No se realizan
- No lo sé

8.1.2. Cobertura de simulaciones sobre sistemas críticos

- Se cubren la mayoría de los sistemas críticos
- Se cubren algunos sistemas críticos
- Se han hecho pruebas aisladas, sin cobertura significativa
- No se han realizado
- No lo sé

8.1.3. ¿Se documentan resultados y lecciones aprendidas de estos ejercicios, y se enlazan con el modelo de amenazas?

- Sí, sistemáticamente
- Sí, pero sin trazabilidad clara al modelo
- De forma informal
- No
- No lo sé

9. Fase 7 PASTA: Análisis de riesgo, impacto, continuidad y ROI

9.1.1. ¿Dispone su organización de una metodología formal de evaluación de riesgo que integre resultados del modelado de amenazas (probabilidad, impacto, criticidad)?

- Sí, plenamente integrada
- Parcialmente integrada
- En fase de integración
- No, se evalúa el riesgo de forma independiente
- No lo sé

9.1.2. ¿Se cuantifican económicamente los riesgos cibernéticos (p. ej. pérdidas potenciales, impacto financiero anualizado)?

- Sí, con modelos cuantitativos aceptados por Finanzas
- Sí, pero con estimaciones aproximadas
- Se utilizan solo categorías cualitativas (bajo/medio/alto)
- No se cuantifica
- No lo sé

9.1.3. ¿Se utilizan indicadores de madurez global (IGM) que combinen aspectos de gobernanza, capacidades técnicas, modelado de amenazas y respuesta a incidentes?

- Sí, con un modelo formal y repetible
- Sí, pero limitado a algunos ámbitos
- Se manejan métricas dispersas sin un índice integral
- No
- No lo sé

9.1.4. En relación con el retorno de inversión (ROI) en ciberseguridad y, específicamente, en actividades de modelado de amenazas, ¿cómo se mide o justifica internamente?

- Se calcula ROI o reducción de pérdidas esperadas
- Se vincula a reducción de incidentes y a indicadores de resiliencia
- Se justifica mediante cumplimiento normativo y auditorías
- No se mide ni se justifica explícitamente
- No lo sé

10. Zero Trust, cadena de suministro y contexto ampliado

10.1.1. ¿Ha adoptado su organización principios o arquitecturas Zero Trust de forma explícita?

- Sí, con estrategia formal y hoja de ruta
- Sí, parcialmente y por dominios (identidad, red, datos)
- En fase de diseño
- No, no se ha considerado
- No lo sé

10.1.2. ¿Se emplea el modelado de amenazas para analizar dependencias de terceros, proveedores, servicios cloud y cadena de suministro?

- Sí, con escenarios específicos y métricas
- Sí, parcialmente
- Sólo a través de cuestionarios estándar
- No
- No lo sé

11. Talento, herramientas y automatización

11.1.1. Tamaño aproximado del equipo dedicado (total o parcialmente) a gestión de riesgos y modelado de amenazas

- 0 personas dedicadas (se gestiona “en ratos libres”)
- 1–2 personas
- 3–5 personas
- Más de 5 personas
- No lo sé

11.1.2. Nivel de especialización del equipo en PASTA/STRIDE u otras metodologías similares

Escala 1–5 (1 = desconocimiento, 5 = expertos internos y formadores).

- 1
- 2
- 3
- 4
- 5

11.1.3. ¿Se utilizan herramientas específicas de modelado de amenazas o plataformas de gestión de riesgos que apoyen la metodología?

- Sí, herramientas dedicadas de Threat Modeling
- Sí, plataformas GRC integradas con modelado de amenazas
- Herramientas ofimáticas (diagramas, hojas de cálculo, documentos)
- No se utilizan herramientas específicas
- No lo sé

11.1.4. ¿Se emplea automatización (p. ej. generación automática de amenazas, integración CI/CD, IaC) en el proceso de modelado de amenazas?

- Sí, con integración en pipelines de desarrollo/deploy
- Sí, pero de forma limitada
- No, se realiza manualmente
- No lo sé

12. Cierre y autoevaluación

12.1. En una escala de 1 a 5, ¿cómo valoraría la madurez global de su organización en modelado de amenazas (PASTA, STRIDE u otras), considerando proceso, herramientas, talento y resultados?

- 1 (incipiente)
- 2
- 3
- 4
- 5 (avanzado y continuo)

12.2. ¿Qué considera usted que es el principal obstáculo para mejorar el modelado de amenazas y la gestión de riesgo en su organización?

Respuesta abierta:

12.3. ¿Desea recibir un resumen comparativo (benchmark anónimo) de resultados frente a organizaciones similares?

- Sí
- No

Fin de la encuesta. Si ha llegado hasta aquí, enhorabuena: ya ha hecho más por la resiliencia de su organización que muchos presupuestos enteros dedicados a fuegos artificiales tecnológicos.